

GOVERNANCE / INTEROPERABILITY / RECOVERY

AI Governance and Interoperability Controls

A future-facing field report for leaders who are moving AI from impressive demonstrations into consequential work: the operating layer where data, agents, APIs, people, permissions, evaluation, security, and recovery have to function as one system.

Format: executive field report **Use:** AI portfolio, platform, risk, or operating-model review **Read:** 45–55 minutes

Workshop: 90 minutes with a service owner and control owners



AI governance is an operating capability: people, permissions, evidence, and recovery are visible around the workflow.

The thesis

AI is becoming a governed operating layer. The winners will not be the organizations with the most pilots or the most impressive model demos. They will be the organizations that can connect intelligence to trusted data, move decisions through interoperable systems, preserve human authority where it matters, evaluate behavior in the real workflow, contain security failures, and recover without losing the thread of accountability.

Governance is therefore not a review performed after deployment. It is the architecture that makes deployment repeatable.

Executive readout

The public conversation often treats AI governance as a choice between acceleration and restraint. That is the wrong frame for an operating enterprise. A useful control system does not ask whether an organization is “for” or “against” AI. It asks where intelligence can create durable value, what authority the system is allowed to exercise, what evidence a person must see before acting, how the result travels into the next system, and how quickly the organization can stop or repair the workflow when the answer is wrong.

This report takes a strong position: the next governance advantage will come from integration, not documentation volume. A policy that is not encoded into permissions, interfaces, evaluation, review queues, deployment gates, and recovery drills is an aspiration. A model card that does not change what the workflow permits is context, not control. A human-in-the-loop diagram that leaves the human with no time, evidence, training, or authority is theater.

The practical consequence is a shift in the unit of design. The unit is no longer the model. It is the **governed capability**: a purpose-bound combination of data, models or rules, agent tools, interfaces, people, permissions, evaluation, observability, and recovery. Leaders should govern that capability as a service with a clear owner, not as a technical object that can be approved once and forgotten.

LEADERSHIP QUESTION	WEAK ANSWER	OPERATING ANSWER
What are we deploying?	"An AI assistant."	A named workflow capability with a defined purpose, user, authority, data boundary, and outcome.
How do we know it works?	"The demo looked accurate."	Evaluation tied to representative cases, failure costs, escalation behavior, latency, and user decisions.
Who is accountable?	"The vendor" or "the model team."	A service owner who can change, pause, or retire the capability, with named control owners around them.
What happens when it fails?	"A person is in the loop."	A tested fallback, stop authority, incident path, user notification, and recovery record.
Can we scale it?	"It worked in one department."	Its identity, contracts, metadata, permissions, monitoring, and operating rhythm travel with it.

Why the control question has changed

Organizations are moving from isolated experiments toward AI inside operations, public services, infrastructure, health, and enterprise platforms. That changes the consequence surface. The model may generate the text, score, recommendation, or action, but the consequence is carried by the workflow around it: a person acts on a recommendation, a system changes a queue, a partner receives a data product, a customer is routed to a different service, or an operational decision is accelerated.

Public signals point in the same direction. The ONC brief cited in this report describes widespread hospital API access alongside uneven standards-based exchange with third-party technology. NATO's digital strategy connects data labeling, metadata, access control, federated identity, interoperability, responsible use, and mission continuity through a future planning horizon. Those are not isolated technical concerns. They describe the connective tissue required for a digital operating model that can be trusted across organizational boundaries.

Three changes follow.

- ☐ **Intelligence is becoming composable.** A workflow may call several models, retrieval systems, tools, data products, and human queues. The risk is in the composition and handoff, not only in any one component.
- ☐ **Agents are moving the boundary from answer to action.** The important question becomes what an agent can read, write, invoke, approve, purchase, schedule, or change, and under whose authority.
- ☐ **Interoperability is becoming a governance control.** Reliable identity, metadata, schemas, audit events, and failure semantics make it possible to know what moved, why it moved, and what should happen next.

The strategic risk is not simply that a model is inaccurate. It is that an organization creates a fast, opaque, cross-system dependency that no single team can explain or stop. The strategic opportunity is the opposite: create an operating layer where intelligence is observable, permissioned, replaceable, and accountable enough to become infrastructure.

The governed operating layer

Think of the capability as a loop rather than a stack. The request begins with a purpose and an authorized identity. Data and context are assembled under a contract. A model, rule, or agent produces a recommendation or attempts a bounded action. The workflow evaluates the result, gives a person the authority and evidence to decide where required, and records what happened. The service then measures outcomes, detects drift or abuse, and recovers when a component or assumption fails.

The diagram below is deliberately operational. It shows that governance is not a gate placed in front of a model. It is the set of controls that travel with the request through the system and return with evidence.

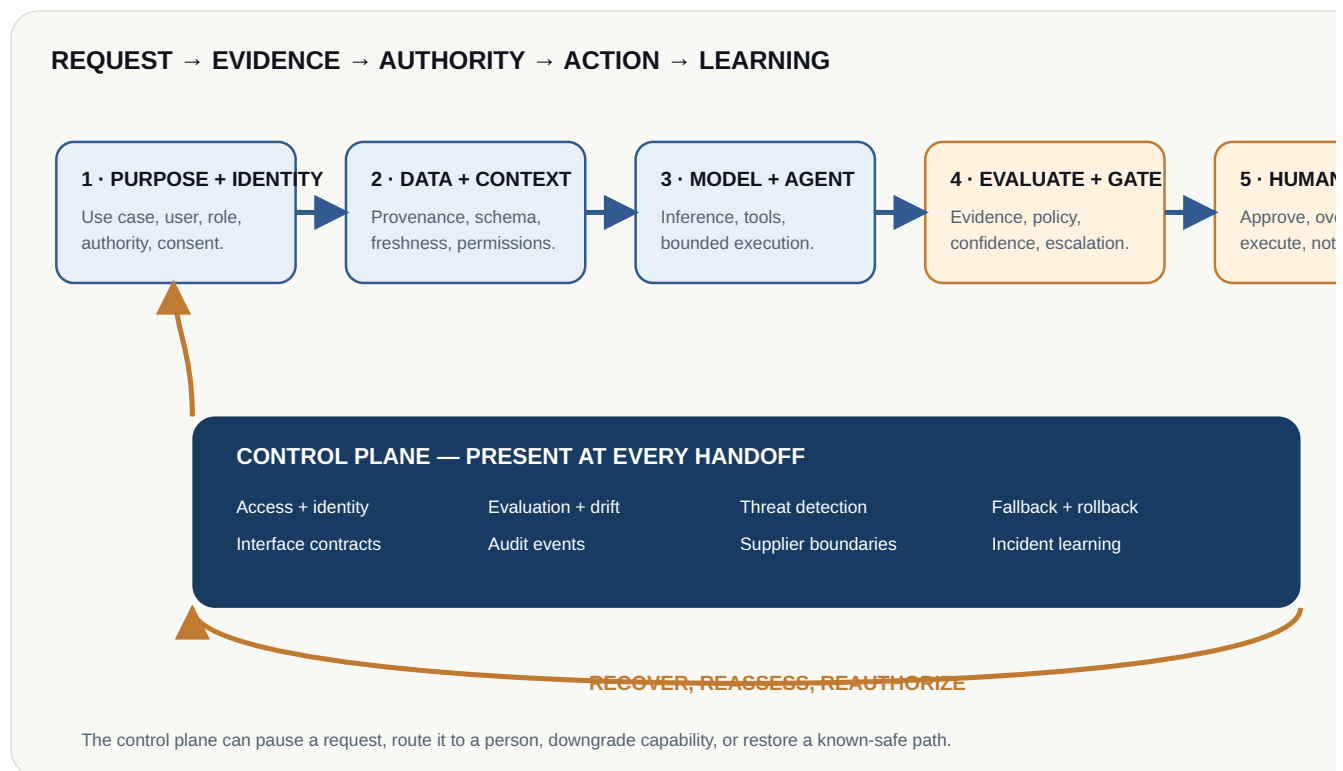


Figure 1. The operating unit is a governed capability. The horizontal path moves work forward; the control plane preserves identity, evidence, policy, observability, security, and recovery across every handoff.

► Text equivalent

Design the control plane before the feature list

Most AI programs start with a list of possible features: summarize, classify, recommend, draft, search, route, automate. The more durable starting point is a control-plane inventory. Ask what every capability needs in order to be trusted: identity, purpose, permitted inputs, data provenance, tool permissions, model and prompt versions, evaluation evidence, human decision rights, audit events, monitoring, cost boundaries, and recovery.

This inventory becomes a reusable product. When a new capability is proposed, the team does not reinvent governance. It selects a pattern, fills the evidence gaps, and makes the exceptions visible. The executive benefit is comparability across the portfolio. A board or investment committee can see not only which idea is attractive, but which capabilities are governed well enough to scale.

Interoperability is a governance control

Interoperability is often discussed as plumbing: APIs, schemas, message formats, identity federation, and integration work. In an AI operating layer it is more consequential. Interoperability determines whether a recommendation retains its meaning when it crosses a system boundary, whether a human can see the evidence behind it, whether permissions travel with the request, and whether a failure can be isolated rather than amplified.

A mature interface is not just an endpoint. It is a compact agreement about **meaning, authority, provenance, timing, and failure**.

CONTRACT ELEMENT	WHAT TO SPECIFY	WHY IT MATTERS FOR AI CONTROL
Meaning	Field definitions, units, labels, allowed values, interpretation.	Prevents a plausible output from being acted on with the wrong meaning.
Provenance	Source, version, transformation, timestamp, responsible owner.	Lets a reviewer understand what evidence the system actually used.
Authority	Calling identity, role, scope, consent, delegation, expiry.	Prevents a tool from gaining more power simply because it was composed into a new workflow.
Timing	Freshness, latency, ordering, replay behavior, timeout.	Distinguishes a current signal from a stale one and defines safe behavior under delay.
Failure	Validation errors, partial response, unavailable dependency, retry and fallback.	Turns an integration failure into an observable state instead of a silent guess.
Accountability	Correlation ID, decision event, user-visible explanation, retention boundary.	Connects the request, evidence, action, and incident record without requiring forensic reconstruction.

Leaders should be suspicious of a capability that is accurate only inside its original interface. If a result cannot carry identity, provenance, confidence or uncertainty, and a clear next action into the receiving workflow, it may be a demo rather than an enterprise capability. The test is not whether two systems can exchange bytes. The test is whether a responsible person can act on the exchange without losing context or authority.

Interoperability also creates strategic option value. A capability with stable contracts can change models, suppliers, retrieval systems, or orchestration layers without forcing the entire operating process to be rebuilt. That does not mean every component should be interchangeable on day

one. It means the organization should know which boundaries are stable, which are experimental, and what evidence must be regenerated when a dependency changes.

Agents change the unit of control

An agent is not simply a more conversational model. In an operating environment, an agent can plan, select tools, retrieve context, call services, write records, ask for approval, and continue a task across time. That makes the control boundary wider and more dynamic. A prompt may describe intent, but it does not by itself provide a sufficient authority model.

The right question is not “Is the agent autonomous?” Autonomy is too blunt a label. Ask instead:

☐ What information may the agent read, and from which identity boundary?

☐ What tools may it discover and invoke?

☐ Which actions are reversible, and which create an external or durable consequence?

☐ Can it delegate, create another agent, or hand a task to a third party?

☐ What is the maximum time, spend, volume, or data scope for one run?

☐ What evidence must be attached to every proposed action?

☐ What conditions pause the run and require a human?

- ☐ Can an operator reconstruct and terminate a run without relying on the agent to explain itself?

Use a capability ladder rather than a binary approval.

AGENT CAPABILITY	DEFAULT POSTURE	CONTROL EMPHASIS
Read and summarize	Low consequence when sources and data boundaries are clear.	Source visibility, sensitive-data handling, uncertainty, user challenge.
Prepare a draft	Human remains responsible for the submitted artifact.	Attribution, review quality, prohibited content, version and evidence record.
Recommend a decision	Decision owner must remain visible and empowered.	Representative evaluation, disparate failure investigation, override and escalation.
Change an internal record	Bounded execution with reversibility.	Least privilege, transaction log, validation, approval thresholds, rollback.
Act across organizations	High boundary sensitivity.	Delegation, contract, consent, identity federation, notification and dispute path.

Build agent controls into the tool layer. A safe tool should declare what it does, what inputs it accepts, which identity it uses, what it can change, what it returns, and what happens when it is called twice. An agent should not be able to discover an undocumented power simply because an endpoint happens to be reachable. Tool registration, scopes, rate limits, approval requirements, and audit events are part of the product.

The future-facing implication is important: the enterprise may soon have many specialized agents operating across a shared workflow. The advantage will not come from making each agent clever in isolation. It will come from a common authority model and a common exchange language so that agents can coordinate without silently inheriting one another's permissions. The control plane becomes the platform differentiator.

Evaluation becomes operating instrumentation

Evaluation is often treated as a pre-launch score. That is too narrow for a capability that changes over time. Models change. Prompts change. retrieval sources change. Users adapt. Data drifts. Suppliers alter latency or behavior. The workflow itself evolves. Evaluation must therefore operate like instrumentation: a continuing way to observe whether the capability is producing the intended outcome under the conditions that matter.

Start with a failure taxonomy. “Wrong answer” is not specific enough to manage. A service owner should distinguish at least:

☐ **Unsupported output:** the answer cannot be traced to approved evidence.

☐ **Misinterpretation:** the system used a valid input with the wrong meaning or context.

☐ **Omission:** a material fact, exception, or required step was absent.

☐ **Overreach:** the system expressed more certainty or authority than the evidence supports.

☐ **Misrouting:** the work reached the wrong team, queue, person, or jurisdiction.

☐ **Unsafe execution:** a tool call created an unintended or irreversible consequence.

☐ **Control failure:** a review, permission, alert, or stop path did not work when needed.

☐ **Recovery failure:** the organization could not identify, contain, communicate, or restore the service.

Then connect each failure type to a detection signal and an action. A useful evaluation pack combines curated test cases, production samples handled under the organization's privacy rules, adversarial or edge cases, human review, and workflow outcome measures. It should include cases where the system ought to abstain, ask for clarification, or escalate. A system that always answers can look productive while quietly removing the most important safety behavior.

EVALUATION QUESTION	EXAMPLE EVIDENCE	DECISION IF WEAK
Did the system understand the task?	Task classification, clarification rate, correct routing.	Redesign intake, narrow scope, or require a structured request.
Did it use appropriate evidence?	Source attribution, retrieval quality, freshness, citation review.	Fix data contract, retrieval boundary, or abstention behavior.
Did the output support a good decision?	Expert review, override reasons, downstream rework, outcome quality.	Change the interface, evidence display, authority boundary, or workflow.
Did it behave safely under pressure?	Prompt injection tests, malformed inputs, tool failures, rate limits.	Block the release, reduce permissions, add a guard, or redesign the path.
Did it remain useful over time?	Drift indicators, user feedback, latency, cost, service-level behavior.	Recalibrate, retrain, replace, pause, or retire.

Do not let a single score become the organization's definition of quality. A high average can hide a small number of unacceptable failures. A lower score can be acceptable in a low-consequence drafting task if the user has strong review and the system is transparent. Evaluation has to be proportional to consequence, but proportional does not mean informal. It means the organization can explain why the evidence is enough for this use and not another.

Human authority is a system property

“Human in the loop” is not a control unless the human has four things: **authority, time, evidence, and a usable alternative**. If a reviewer cannot reject the output, does not see the relevant context, is measured only on speed, or has no path when the system is unavailable, the person is functioning as a rubber stamp or a liability shield.

Define authority in the workflow itself. The interface should make clear whether the person is checking facts, exercising judgment, approving an action, accepting a risk, or simply acknowledging that the system ran. Those are different responsibilities. The audit record should preserve the distinction.

Human authority also has to survive organizational change. A capability may move from a pilot team into a shared service, then into a partner workflow. At each boundary, confirm who owns the decision, who can pause the system, who handles an appeal, and which evidence is visible to the next person. If accountability becomes ambiguous when the workflow crosses a department, the design is not ready to scale.

Strong human authority includes dissent as a first-class outcome. Build an “I disagree,” “insufficient evidence,” or “send to specialist” path that does not punish the reviewer for using it. Capture override reasons in a way that supports learning without turning every disagreement into a performance accusation. Over time, these records may reveal that the system’s most valuable improvement is not a larger model but a clearer data contract or a better queue design.

Security, resilience, and recovery

AI introduces familiar security problems in unfamiliar combinations. Sensitive data may be retrieved into a prompt. A tool may be called with a broader identity than the user intended. An external instruction may attempt to redirect an agent. A supplier may change behavior without changing the interface. Logs may contain the very information the organization was trying to protect. A control plan that focuses only on model output misses the attack surface around the model.

Use a threat model that follows the request end to end:

- ☐ **Input boundary:** What can enter through users, files, connectors, retrieval, or another agent? Which content is untrusted?

- ☐ **Context boundary:** What is selected, retained, transformed, or exposed to the model? Can the user see the material that shaped the result?

- ☐ **Tool boundary:** Which calls can read, write, send, purchase, schedule, delete, or change state? Which are reversible?

- ☐ **Identity boundary:** Is the action performed as the user, as a service, or as a delegated principal? Can that identity be revoked quickly?

- ☐ **Output boundary:** Where can the result travel? Can untrusted text be mistaken for an instruction by the next system?

- ☐ **Observation boundary:** What is logged, who can access it, how long is it retained, and what sensitive material must be redacted?

- ☐ **Supplier boundary:** Which providers, model endpoints, data processors, or infrastructure dependencies can affect the service?

Recovery should be designed before launch, not improvised after an incident. Define a safe mode. It may mean human-only processing, a read-only experience, a lower-privilege model, a smaller data set, a queue with explicit delay, or a known-good previous version. The right fallback depends on the service; the principle is constant: the organization must be able to reduce capability without abandoning the people who depend on the workflow.

Exercise the recovery path. Revoke a tool credential. Make a data dependency unavailable. Send a malformed or adversarial input. Introduce a stale source. Simulate a model or supplier change. Ask whether the service detects the condition, who receives the alert, who has stop authority, how users are notified, whether work can continue safely, and how the organization knows it has restored the right behavior. The exercise is not a claim that failure is impossible. It is evidence that failure is survivable.

Board-level test

Ask the executive owner to demonstrate a live stop, a human fallback, and a reconstruction of one recent decision. If the organization can show only a policy PDF or a model score, governance is not yet an operating capability.

Build a governance rhythm that makes decisions

A control becomes part of the operating model when it has an owner, a signal, a threshold, a decision, and a next review date. Meetings should not exist to admire dashboards or repeat policy language. They should decide whether a capability scales, narrows, pauses, changes, or retires.

- ☐ **Weekly workflow review:** exceptions, overrides, abstentions, user feedback, queue behavior, and open incidents. The decision is usually a small change to the workflow or evaluation set.

- ☐ **Monthly service review:** outcome measures, cost, latency, dependency changes, drift, security signals, recovery readiness, and proposed releases. The decision is whether the service remains within its authority boundary.

- ☐ **Quarterly portfolio review:** scale, pause, retire, redesign, or invest. The decision is whether the portfolio still fits the mission, risk appetite, and capacity of the organization.

- ☐ **Event-driven review:** a material model, data, supplier, identity, policy, legal, or infrastructure change. The decision is whether existing evidence still applies.

The evidence pack for each review should be short enough to read and rich enough to decide: what changed, what the system did, where it failed, what people challenged, what it cost, which dependencies moved, and what decision is required. Treat exceptions as learning signals rather than embarrassing noise. A rising abstention rate may indicate healthy caution or a broken intake; the meeting exists to distinguish them.

Assign one accountable service owner. Surround that owner with control owners for data, security, platform, process, legal or privacy review as appropriate. Do not create a committee that owns everything and can change nothing. A committee can set thresholds and resolve conflicts; the service owner must still be able to ship, pause, and retire.

A practical implementation sequence

Organizations often try to solve governance by writing a universal policy before they understand the operating patterns. A better sequence is to establish a small number of repeatable capability patterns, then learn from them.

- ☐ **Choose a consequential but bounded workflow.** Avoid a toy demo and avoid the most irreversible decision first. Pick a service where better evidence, routing, drafting, or prioritization can be observed.
- ☐ **Name the owner and write the authority boundary.** State what the capability may do, may not do, and may do only with approval.
- ☐ **Map the request and data contract.** Identify sources, fields, provenance, freshness, identity, sensitive data, and failure behavior.
- ☐ **Define the evaluation and abstention plan.** Create representative cases, edge cases, unacceptable failures, human review criteria, and production feedback loops.
- ☐ **Build the control plane into the interface.** Make permissions, audit events, evidence, confidence, escalation, and recovery visible where work happens.
- ☐ **Run a security and recovery exercise.** Demonstrate stop, revoke, fallback, notification, reconstruction, and restoration.

- ☐ **Review the operating cost.** Include model calls, human review, integration, monitoring, storage, support, and the cost of a bad or delayed decision.

- ☐ **Scale the pattern, not the exception.** Package reusable contracts and controls. If a new use case requires a different boundary, make the difference explicit.

This sequence is intentionally opinionated. It treats governance as product design and operational learning. The organization should be able to say, “We know how this capability is allowed to work, we know how to tell whether it is working, and we know how to stop it,” before it says, “We are ready to put it everywhere.”

Implementation worksheet

Use this page in a working session. Complete it with the outcome owner, technical owner, security or privacy representative, and a person who performs the real workflow. Blank answers are not neutral; they are open control decisions.

Capability boundary

Write in plain language. If a field cannot be answered, record who will answer it and by when.

1. Service or decision: What real work is being improved, for whom, and why now?

2. Intended outcome: What would be measurably better if this capability worked? What outcome must not degrade?

3. Authority class: Is it assist, recommend, route, or execute? What action is explicitly out of scope?

4. Decision owner: Who remains accountable for the result? Who can pause, change, or retire the service?

5. Human authority: Where must a person review, approve, override, escalate, or communicate? What time and evidence do they have?

6. Inputs and provenance: Which sources, fields, connectors, and documents are approved? How will freshness, quality, and origin be shown?

7. Agent and tool permissions: What may the system read, write, invoke, delegate, or change? What is the maximum scope, time, volume, and spend?

8. Interoperability contract: What identity, schema, metadata, correlation ID, timeout, retry, and failure semantics cross each boundary?

9. Evaluation: What representative cases, edge cases, abstentions, unacceptable failures, human review, and outcome signals will be tested?

10. Security: What can be untrusted? Where can data leak, permissions expand, instructions be injected, or logs expose sensitive material?

11. Recovery: What is the safe mode? Who can stop the capability? How are users notified? What evidence proves restoration?

12. Governance decision: Scale, narrow, pause, redesign, or retire? What evidence supports the decision, and when is the next review?

Readiness conversation

SIGNAL	GREEN: EXPLAINABLE AND TESTED	AMBER: OWNER AND EVIDENCE NEEDED	RED: DO NOT SCALE YET
Authority	Bounded and visible in the workflow.	Boundary exists but is not consistently enforced.	No one can state who may stop or approve.
Evidence	Sources, uncertainty, and decision record travel with the result.	Evidence exists in another system or is difficult to review.	Output cannot be traced or challenged.
Recovery	Fallback and stop path exercised recently.	Plan exists but has not been tested under realistic conditions.	No safe mode, owner, or restoration evidence.
Interoperability	Contracts preserve meaning, identity, and failure states.	Exchange works but metadata or failures are inconsistent.	Handoff silently loses context or expands authority.

Counterpoints, limits, and where this thesis can fail

A strong thesis should survive disagreement. There are legitimate reasons to resist a broad “AI operating layer” program, and governance can create its own failure modes.

“Some use cases are too small for this.”

Correct. A low-consequence drafting assistant may not need the same evaluation depth or recovery architecture as a system that changes an external record. Proportionality matters. The answer is not to remove the control model; it is to scale the evidence and authority boundary to the consequence. A lightweight pattern should still state its purpose, data boundary, user challenge path, and owner.

“Interoperability slows us down.”

It can, especially when teams try to standardize every field before learning what the workflow needs. The right goal is not maximal standardization. It is enough contract at the boundary to preserve meaning, identity, authority, and failure. Stable interfaces can be narrower than the underlying systems and can evolve deliberately. The cost of a small contract is usually easier to see than the cost of rebuilding an opaque dependency later.

“Human review does not guarantee safety.”

Agreed. Humans are fallible, overloaded, biased, and capable of approving bad outputs. Human authority is not a magic shield. It is one part of a defense that must be supported by evidence, time, training, clear responsibility, usable escalation, and evaluation of the human-system interaction. In some workflows, a second system check, a hard rule, or a lower-authority design will be more reliable than asking one person to catch everything.

“Models and suppliers change too quickly for documentation.”

That is an argument for versioned evidence and automated controls, not for abandoning documentation. The organization should record what changed, which evaluations were rerun, whether permissions or data flows changed, and who accepted the residual risk. If a change cannot be evaluated, narrow the deployment until it can.

“The board does not need technical detail.”

The board does not need implementation trivia. It does need to know whether the organization can identify authority, material dependency, exposure, failure, and recovery. A concise operating view is more useful than a technical appendix: where AI is consequential, who owns it, what evidence supports it, what can stop it, and what would happen if a supplier or model changed tomorrow.

Finally, this report does not predict that every process will become autonomous or that one architecture will fit every organization. It argues for a durable direction: as intelligence is woven into more workflows, the ability to govern composition, authority, exchange, evaluation, security, and recovery will matter more than the novelty of the model. Organizations should invest in that capability even when the current use case remains modest, because it is the reusable infrastructure that makes future choices safer and faster.

Source notes and use boundaries

The sources below are public starting points for the operating conversation. They are not endorsements of a particular implementation, and they do not replace a use-case-specific threat model, impact assessment, contract review, evaluation set, or legal advice.

- [ONC · Hospital use of APIs to enable data sharing between EHRs and third-party technology](#) — a signal for examining standards-based exchange, adoption, and the gap between technical availability and usable interoperability.
- [NATO · Alliance Digital Strategy](#) — a public strategy signal connecting data, metadata, access control, identity, interoperability, responsible use, and continuity across a future planning horizon.
- [NIST · AI Risk Management Framework](#) — a useful voluntary risk-management lens for organizing governance conversations; it is not a certification or proof that a particular capability is safe.
- [CISA, NSA, FBI, and international partners · Secure by Design guidance for AI systems](#) — a security signal for moving responsibility toward the design and supply chain rather than leaving it with the end user.

Use this report in a leadership meeting

Bring the service owner, a frontline operator, a platform or data owner, security or privacy counsel, and an executive sponsor. Ask each person to complete the worksheet independently for ten minutes. Compare the answers. The gaps between them are often the first visible map of the governance work.

This field report is a practical decision aid. It is not a compliance certification, security assessment, clinical safety opinion, legal interpretation, or assurance that a particular model, agent, or supplier is suitable for a particular use. Public evidence can change; verify source status before relying on it for a material decision.

PUBLIC RESEARCH BASIS

- [ONC · Hospital use of APIs to enable data sharing](#)
- [NATO · Alliance Digital Strategy](#)
- [NIST · AI Risk Management Framework](#)
- [CISA et al. · Secure by Design for AI systems](#)

Prepared by Global Enterprise Standard Corporation · [globalenterprise.com](#) · This field report was reviewed August 11, 2026. Public evidence can change; verify source status before relying on it for a material decision.